



AULA 3

Segurança e aspectos éticos de dados



Objetivos de aprendizagem da aula

Ao finalizar desta aula, você irá:

- Explicar “Segurança de Dados”, uma das áreas de conhecimento do DMBOK.
- Explicar os aspectos éticos de dados.
- Explicar o que é a LGPD.
- Explicar o que são Dados Abertos.
- Exemplificar aspectos de Pessoas (estrutura), de Processos (gestão) e de Métricas (Governança) para segurança de dados.

Que história é essa?

Nesta terceira aula, seremos apresentados ao tema de segurança e aspectos éticos de dados. Será descrita a área de conhecimento segurança de dados do *Data Management Body of Knowledge* (DMBOK). Entenderemos aspectos éticos relevantes dos dados, o que é a Lei Geral de Proteção de Dados Pessoais (LGPD) e o que são os dados abertos. Ao final, vamos aprender que aspectos de pessoas, processos e métricas são mais relevantes para gestão e governança da segurança e de aspectos éticos de dados.

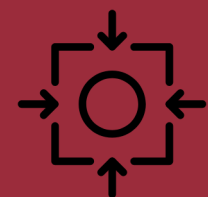
As pessoas utilizam dados o tempo todo. Estamos sempre observando o que acontece ao nosso redor, por exemplo, vendo e escutando. Essa coleta de dados permanente utiliza todos os nossos sentidos. Esses dados, uma vez coletados, são interpretados e a informação que deles nasce é utilizada para tomarmos decisões no

dia a dia. Os dados e as informações que consideramos, conscientemente ou não, mais relevantes são guardados na nossa memória de longo prazo.



Embora nossa memória possa falhar, por exemplo, quando esquecemos alguma coisa ou lembramos algo que aconteceu de uma forma um pouco diferente, apenas você tem acesso a essa memória. Não há tecnologia conhecida capaz de ter acesso direto à sua memória.

Os dados utilizados por empresas, sejam eles gerados internamente ou não, são cada vez mais digitalizados e armazenados em arquivos e banco de dados. O correto é que apenas as pessoas autorizadas sejam capazes de inserir novos dados, ver dados armazenados, alterar esses dados e descartá-los quando for apropriado. No contexto de uma organização, isso cabe à área de Tecnologia da Informação (TI), seja na operacionalização dessa segurança, seja na orientação de seus usuários.



Mantendo o foco

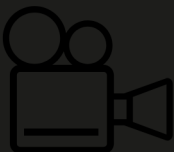
Do ponto de vista das trocas comerciais, sejam de produtos ou serviços, nenhuma empresa é uma ilha. Da mesma forma, com o surgimento da internet, todas as empresas estão digitalmente conectadas. Muitos produtos de informação e serviços são solicitados, realizados e entregues pela internet. Todos estão conectados: as pessoas, as empresas e os governos de qualquer esfera (federal, estadual, municipal).

Da mesma forma que traz benefícios tangíveis, essa hiperconectividade apresenta ameaças reais. As empresas passaram a ter que se preocupar muito mais com a segurança de suas informações.

O controle de acesso físico às suas instalações, a portaria onde os visitantes têm que se identificar, as portas e os alarmes não são suficientes para garantir que os dados armazenados em arquivos e bancos de dados não sejam indevidamente utilizados.

Não é incomum, hoje em dia, ser noticiado que dados de determinada empresa foram vazados, ou seja, divulgados amplamente de forma não autorizada.

Também não são raras as situações nas quais empresas têm seus dados sequestrados, ou seja, criptografados e tornados indisponíveis para uso.



Sequestro de dados

No vídeo a seguir, compreenda o que é sequestro de dados e como evitar ou mitigar sua ocorrência.



E os dados na sua empresa, estão protegidos contra acesso indevido?

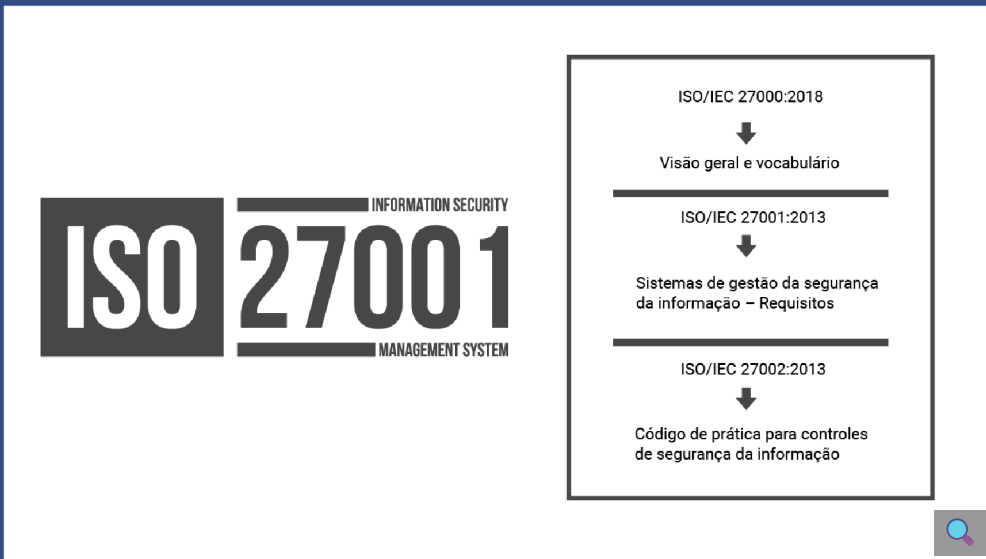


Fique ligado

Apenas as pessoas autorizadas podem ver os dados? É garantido que nenhum dado pode ser alterado por pessoa não autorizada?

Um referencial muito utilizado em todo o mundo para a definição de políticas e procedimentos de segurança da informação é a família de normas ISO/IEC 27000 (*information technology – security techniques*).

As primeiras normas dessa família provêm de muita informação para quem quer se organizar para preparar uma Política de Segurança da Informação (PSI) e acompanhar a sua implantação:



A primeira seção de controle de segurança da informação da norma ISO/IEC 27002:2013, p.8 trata de políticas de segurança da informação, que trazem em seu teor:

Convém que um conjunto de políticas de segurança da informação seja definido, aprovado pela direção, publicado e comunicado para todos os funcionários e partes externas relevantes. [...] Convém que no mais alto nível a organização defina uma política de segurança da informação, que seja aprovada pela direção e estabeleça a abordagem da

organização para gerenciar os objetivos de segurança da informação.

A mesma norma, ISO/IEC 27002:2013, p.8, enfatiza a necessidade de alinhamento estratégico (atividade de responsabilidade da governança) e *compliance*:

Os requisitos de segurança que devem ser considerados para a elaboração de tais políticas são oriundos [...] da estratégia do negócio; de regulamentações, legislação e contratos; e do ambiente de ameaça da segurança da informação, atual e futuro.

Em particular, a norma ISO/IEC 27001:2013 cita objetivos de controle organizados em 14 domínios:

- 1. Políticas de Segurança da Informação
- 2. Organização da Segurança da Informação
- 3. Segurança em Gestão de Pessoas
- 4. Gestão de Ativos
- 5. Controle de Acesso
- 6. Criptografia
- 7. Segurança Física e do Ambiente
- 8. Segurança nas Operações
- 9. Segurança nas Comunicações
- 10. Aquisição, Desenvolvimento e Manutenção de Sistemas
- 11. Relacionamento na Cadeia de Suprimento
- 12. Gestão de Incidentes de Segurança da Informação
- 13. Aspectos de Segurança da Informação de Gestão da Continuidade do Negócio
- 14. Conformidade

Um domínio agrupa diversos “objetivos de controle”, cada um com sua definição e suas diretrizes para a implantação de controles. Esses objetivos podem ser os principais norteadores na definição e manutenção de uma PSI.

Segurança de dados segundo o DMBOK

O DMBOK tem uma área de conhecimento inteiramente dedicada à segurança de dados.

A gestão da qualidade de dados, segundo o DMBOK, é responsável pela “**definição, planejamento, desenvolvimento e execução de políticas e procedimentos de segurança para fornecer autenticação, autorização, acesso e auditoria adequados de ativos de dados e informações**” (DAMA..., 2017, p. 219).

Clique nos boxes e compreenda mais os objetivos da gestão da qualidade de dados.

Interativo

Descrição do interativo

A ética diz respeito ao que consideramos ser correto para vivermos em sociedade. Quando falamos em uso ético de dados, estamos falando que dados precisam ser usados de forma correta para o bem e em prol da sociedade.

Como buscar, armazenar, gerenciar, interpretar, analisar, utilizar e descartar dados de forma alinhada a princípios éticos?



Aprenda Mais

Uma forma de tangibilizar as possíveis soluções de uso ético de dados é definir os seus princípios, em especial no que se refere aos dados pessoais.

Entenda Melhor

O primeiro aspecto a ser considerado é que os dados precisam ser obtidos de forma legal, ou seja, dentro da lei vigente. Deve haver transparência em como eles foram coletados, de tal forma que as partes interessadas possam perceber sua legitimidade.





Dados precisam ser coletados com clareza de como serão utilizados. Não é correto solicitar dados cuja finalidade não esteja definida. Por exemplo, não é razoável o controle de acesso a um edifício comercial solicitar a informação se a pessoa é casada ou não, pois tal informação não é útil ou necessária para tal controle de acesso. Assim, devem ser coletados apenas os dados minimamente necessários para o desempenho de determinadas atividades.

Dados também precisam ser coletados de forma precisa com qualidade. Não é razoável supor que um cliente de uma loja *on-line* informe o seu endereço para recebimento de um produto recém-comprado e esse endereço seja registrado pela loja de forma incorreta, causando prejuízo para o cliente.



Os dados pessoais também devem ser armazenados apenas quando forem necessários. Uma vez que cesse a necessidade de sua utilização, eles precisam ser descartados.

Os dados pessoais precisam ser coletados e processados de forma a manter a sua confidencialidade e integridade. Eles não podem nem ser utilizados nem ser modificados por pessoas não autorizadas.

A empresa responsável pela coleta e pelo processamento de dados pessoais precisa ser responsabilizada caso algum dos princípios éticos de utilização de dados não seja obedecido e haja prejuízo para a pessoa se os dados foram coletados.



A coleta e o processamento de dados precisam ser consentidos, ou seja, a pessoa precisa explicitamente permitir a utilização dos dados que foram adquiridos e tratados.

Devem existir salvaguardas adequadas e auditáveis de modo a garantir que o tratamento dos dados pessoais seja realizado segundo os princípios éticos.

Muitos desses princípios éticos foram observados na criação da Lei Geral de Proteção de Dados Pessoais (LGPD), a ser apresentada mais adiante nesta aula.



Vamos considerar um cenário onde os dados foram coletados e tratados de forma ética. Ainda assim, é possível uma utilização inadequada desses dados de modo a produzir análises incorretas? Clique nos slides para compreender melhor.

Interativo

Descrição do interativo

Em um estudo que vai utilizar dados, é necessário que as definições e os conceitos sejam especificados de forma precisa, de modo a não permitir dúvida a respeito do que os dados representam e se eles podem ser comparados entre si.

https://pucrio.grupoa.education/plataforma/course/2799406/content/55351102

6/11

Outro ponto de preocupação na análise de dados é a escolha de dados com algum viés ou tendência. A amostra de dados a ser utilizada precisa ser definida com rigor para evitar esse tipo de problema.



Fique ligado

Um dos princípios fundamentais para uma boa análise de dados é que eles sejam fidedignos e tenham qualidade. É necessário garantir que procedimentos de qualidade de dados sejam realizados antes que um conjunto de dados seja utilizado para análise.

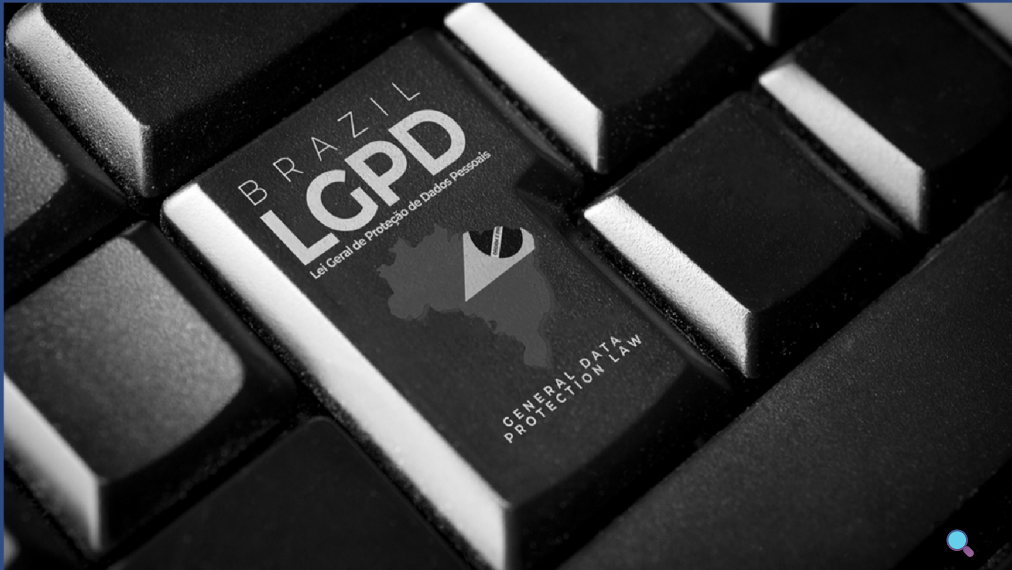
Por fim, especialmente quando se utilizam dados pessoais para análises, é importante que eles sejam anonimizados, de modo a garantir que nenhuma análise poderá levar à divulgação não autorizada dos dados de um indivíduo.

LGPD

Em 2018, foi promulgada a Lei Geral de Proteção de Dados Pessoais (Lei nº 13.709/2018). O artigo 1º traz que a lei

dispõe sobre o tratamento de dados pessoais, inclusive nos meios digitais, por pessoa natural ou por pessoa jurídica de direito público ou privado, com o objetivo de proteger os direitos fundamentais de liberdade e de privacidade e o livre desenvolvimento da personalidade da pessoa natural (BRASIL, 2018, on-line).

A LGPD entrou em vigor em setembro de 2020, e as principais partes interessadas citadas nela são: o titular (a quem se referem os dados pessoais), o controlador (que decide como será realizado o tratamento dos dados) e o operador (que realiza o tratamento dos dados). A lei também definiu a criação da Autoridade Nacional de Proteção de Dados (ANPD).



Uma das características dessa lei é que os dados de um titular só podem ser capturados e tratados para fins previamente declarados por aqueles que os captura e trata, ou seja, o controlador e o operador, respectivamente. A LGPD considera que há dados pessoais e dados sensíveis.

Segundo a lei, os dados sensíveis:

“são os que revelam origem racial ou étnica, convicções religiosas ou filosóficas, opiniões políticas, filiação sindical,

questões genéticas, biométricas e sobre a saúde ou a vida sexual de uma pessoa” (BRASIL, 2018, *on-line*).

Via de regra, dados de crianças e adolescentes necessitam de consentimento de pelo menos um dos pais para que sejam coletados



A LGPD foi inspirada em uma lei europeia semelhante chamada *General Data Protection Regulation* (GDPR) e visa proteger o titular dos dados. Observe que ao mesmo tempo que aponta para aspectos éticos do uso dos dados, também tem preocupação com a sua segurança, pois qualquer vazamento é de responsabilidade dos chamados “agentes de tratamento” dos dados (controlador e operador).

A lei, em seu Capítulo VII, trata de questões de segurança e de boas práticas para garantir a segurança dos dados e a governança. Em particular, o artigo 50 menciona:

Os controladores e operadores, no âmbito de suas competências, pelo tratamento de dados pessoais, individualmente ou por meio de associações, poderão formular regras de boas práticas e de governança que estabeleçam as condições de organização, o regime de funcionamento, os procedimentos, incluindo reclamações e petições de titulares, as normas de segurança, os padrões técnicos, as obrigações específicas para os diversos envolvidos no tratamento, as ações educativas, os mecanismos internos de supervisão e de mitigação de riscos e outros aspectos relacionados ao tratamento de dados pessoais (BRASIL, 2018, *on-line*).

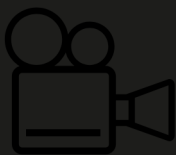
Dados abertos

Ao contrário de dados pessoais, que precisam ser protegidos e corretamente tratados, existem os dados abertos, que podem ser gratuitamente utilizados, reutilizados e redistribuídos, contanto que os aspectos de linhagem e acesso sejam preservados.



Dados abertos são muito interessantes para o enriquecimento de conjuntos de dados.

Por exemplo, os dados de uma empresa sobre a venda de seus produtos nas principais regiões metropolitanas do Brasil podem ser complementados pelo Índice de Desenvolvimento Humano Municipal (IDHM), fornecidos gratuitamente pelo Instituto de Pesquisa Econômica Aplicada (Ipea), no Portal de Dados Abertos do Governo Federal, disponível no *site* dados.gov.br.



Dados abertos

O vídeo a seguir trata sobre a definição, conforme o Banco Mundial, e as principais características dos dados abertos.



Pessoas, processos e métricas

Para a definição de pessoas, processos e métricas relacionados à segurança de dados de uma empresa, é necessário existir um pleno alinhamento estratégico em vários níveis. Por exemplo, as diretrizes e o planejamento da área de TI devem estar alinhados aos da empresa, e da mesma forma as diretrizes que orientam a segurança de dados na empresa devem estar alinhadas às diretrizes e ao planejamento estratégico da TI.

Uma vez que esse alinhamento para a área de dados esteja definido, vamos abordar três aspectos organizacionais necessários para implementar essa área: pessoas, processos e métricas.

Interativo

Descrição do interativo

A PSI precisa ser amplamente divulgada por toda a empresa, uma vez que sua implantação não depende exclusivamente de processos, ferramentas e técnicas de TI, mas também de comportamentos de todos os usuários dos dados, sejam eles colaboradores ou fornecedores externos.



Fique ligado

Uma forma de promover a segurança de dados é promover a capacitação das pessoas responsáveis pela aquisição, pela captura, pela gestão, pelo armazenamento e pela divulgação de dados da empresa em todas as áreas, uma vez que é comum encontrar empresas cujos dados não estão todos sob a guarda da área de TI, por exemplo, sendo armazenados em planilhas eletrônicas de uso departamental.

A PSI também precisa ser periodicamente reavaliada, de modo que os novos riscos à segurança da informação possam ser identificados e mitigados.



A maturidade de processos relativos à segurança de dados é determinante para o sucesso destas atividades. É necessária a existência de uma PSI, pois sem ela não há referência de que processos precisam ser implementados e com que grau de maturidade.

A governança da segurança de dados passa por reuniões regulares e extraordinárias de um comitê de segurança. A avaliação de incidentes mais graves e a tomada de decisão quanto a mudanças na PSI em geral são atribuições desse comitê.

A alta direção da empresa (ou seus representantes) também deve realizar reuniões regulares com a área de TI e com o comitê de segurança, cuja discussão do tema é previsto em pauta, para acompanhamento da implementação da PSI e das métricas estabelecidas para caracterização não apenas do avanço dessas atividades, mas também dos seus efeitos sobre a segurança de dados.



As métricas precisam ser adequadas às iniciativas que estão em desenvolvimento. É comum fazer uma medição antes do início das atividades, muitas vezes conhecido como *baseline*, de tal forma que seja possível avaliar o resultado de tais ações. Essas métricas podem variar, mas seguem algumas sugestões:

- Percentual de políticas da PSI implementadas.
- Grau de conhecimento dos colaboradores acerca da PSI.
- Quantidade de incidentes de segurança, por grau de gravidade.
- Regularidade das reuniões do comitê de segurança.



Referências

Clique aqui para acessar as referências e créditos desta aula.



ASSOCIAÇÃO BRASILEIRA DE NORMAS TÉCNICAS - ABNT. **NBR ISO/IEC 27002:2013**: Tecnologia da informação - Técnicas de segurança - Código de prática para a gestão da segurança da informação. Rio de Janeiro: ABNT, 2013.

BRASIL. **Lei Geral de Proteção de Dados Pessoais (LGPD)**. Ministério do Desenvolvimento e Assistência Social, Família e Combate à Fome, [2023]. Disponível em: <https://www.gov.br/cidadania/pt-br/acesso-a-informacao/lgpd>. Acesso em: 7 jun. 2023.

BRASIL. **Lei no 13.709, de 14 de agosto de 2018**. Lei Geral de Proteção de Dados Pessoais (LGPD). Brasília: Presidência da República, [2019]. Disponível em: http://www.planalto.gov.br/ccivil_03/_ato2015-2018/2018/lei/L13709compilado.htm. Acesso em: 12 jun. 2023.

DAMA International. **DAMA-DMBOK**: data management body of knowledge. New York: Technics Publications, 2017.

OPEN data essentials. **The world bank**, c2019. Disponível em: <http://opendatatoolkit.worldbank.org/en/essentials.html>. Acesso em: 12 jun. 2023.

Banco de imagens Envato, Freepik, Pexels, Pixabay e Shutterstock.